

# Klausur / Exam

## Grundlagen der IT-Sicherheit /

## Foundations of IT Security

H T  
W I  
G N

Prof. Dr. Hanno Langweg

2023-02-02T0900 – 2023-02-02T1030

- 14 Blätter einschließlich Deckblatt / *14 pages including this front page*
- Bearbeitungsdauer: **90 Minuten** / *Available time 90 minutes*
- Zugelassene Hilfsmittel: Keine  
*No permitted examination aids*
- Schreiben Sie Ihre Matrikelnummer auf **jede** Seite  
*Write your student number on **each** page*
- Benutzen Sie nur das Klausurpapier (Rückseite, wenn nötig)  
*Use only paper handed out (use reverse side of page if necessary)*
- Schreiben Sie **lesbar**. Verwenden Sie einen schwarzen oder blauen Stift, keinen roten oder grünen.  
*Write legibly. Use a black or a blue pen, do not use a red or a green one.*

Vorname: \_\_\_\_\_  
*Given name*

NACHNAME: \_\_\_\_\_  
*Family name*

Matrikelnr.: \_\_\_\_\_  
*Student number*

☐

AIN

☐

WIN

☐

Anderer Studiengang  
*(other)*

Regelmäßige Teilnahme an der Lehrveranstaltung in diesem Semester: ☐ ja ☐ nein  
*I attended classes regularly during the semester: yes no*

Allen, die gelernt  
haben, wünsche ich  
viel Erfolg und allen  
anderen viel Glück!

*Good luck!*

1. IT-Grundschutz / IT Base Protection (1 + 1 + 1 + 1 = 4)
2. Schwachstellen / Vulnerabilities (2 + 2 = 4)
3. Malware (2 + 2 + 6 = 10)
4. Zugriffssteuerung / Access Control (4 + 2 + 4 = 10)
5. Positivlisten / Whitelisting (5 + 2 + 6 + 4 = 17)
6. CWE-120, CWE-367 (6 + 3 = 9)
7. Techniken / Techniques (6 + 4 = 10)
8. Microsoft SDL (10)
9. Zertifizierung / Certification (6 + 2 = 8)
10. Passwörter / Passwords (2 + 2 + 2 + 2 = 8)

## 1. IT-Grundschutz / IT Base Protection (1 + 1 + 1 + 1 = 4)

Kreuzen Sie alle richtigen und nur die richtigen Antworten an.

*Mark all correct answers and only correct answers.*

Welche Informationen sind Bestandteil eines IT-Grundschutz-Bausteins?

*What information is part of a module in IT-Grundschutz?*

- ☐ Beschreibungen zu Standard-Sicherheitsmaßnahmen  
*Descriptions of standard security controls*
- ☐ Angaben zur spezifischen Gefährdungslage  
*Notes regarding the specific threat situation*
- ☐ Verweise auf weiterführende Informationen  
*References to additional information*
- ☐ Sicherheitsanforderungen zu einem gegebenen Sachverhalt  
*Security requirements for a given situation/environment*

Worauf sollten Sie bei der Auswahl und Anpassung der Sicherheitsmaßnahmen auf Basis der Anforderungen achten?

*What do you need to take into account when selecting and customising security controls based on requirements?*

- ☐ Auf Wirtschaftlichkeit der Maßnahmen / *How economically efficient security controls are*
- ☐ Auf Wirksamkeit der Maßnahmen / *How effective security controls are*
- ☐ Auf Benutzerfreundlichkeit der Maßnahmen / *How user-friendly security controls are*
- ☐ Auf Grad der Innovation der Maßnahmen / *How innovative security controls are*

Was unternehmen Sie als Informationssicherheitsbeauftragter, wenn die Geschäftsführung nicht bereit ist, den Aufwand für eine bestimmte Sicherheitsmaßnahme zu tragen?

*What do you do as Information Security Officer when the management of your organisation is not willing to bear the effort for a specific security control?*

- ☐ Sie ignorieren die Leitung und setzen die Maßnahme trotzdem um.  
*You ignore management and implement the controls anyway.*
- ☐ Sie verzichten auf eine unmittelbare Reaktion, nehmen sich aber vor, nach Ablauf einer gewissen Zeitspanne die Zustimmung der Leitung einzuholen.  
*You do not react immediately, but you plan for getting management support after a certain time has passed.*
- ☐ Sie verdeutlichen ihr, welche Risiken mit dem Fehlen der Maßnahme verbunden sind.  
*You make clear what risks are associated with the missing security control*
- ☐ Sie bitten die Leitung, durch Unterschrift zu bestätigen, dass sie die damit verbundenen Gefahren kennt und trägt.  
*You ask management for written confirmation that it is aware of the risk and is willing to take it.*

Wer sollte üblicherweise prüfen, ob eine Sicherheitsmaßnahme wie geplant umgesetzt ist?

*Who should usually verify that security controls have been implemented as planned?*

- ☐ Die Geschäftsführung  
*Top level management*
- ☐ Der/Die Informationssicherheitsbeauftragte  
*The information security officer*
- ☐ Der/Die zuständige IT-Administrator/in  
*The responsible IT administrator*
- ☐ Die Leitung der IT-Abteilung  
*The head of the IT department*

## **2. Schwachstellen / Vulnerabilities (2 + 2 = 4)**

Welchen Nutzen haben Datenbanken mit Softwareschwachstellen für den IT-Betrieb?

*What is the benefit in IT operations of using a database of known software vulnerabilities?*

---

---

---

---

---

Wozu dienen CVE-Bezeichner?

*What is the purpose of CVE identifiers?*

---

---

---

---

---

### 3. Malware (2 + 2 + 6 = 10)

Beschreiben Sie zwei Arten, wie Malware auf einem PC zur Ausführung gelangen kann.

*Describe two ways how malware can be executed on a personal computer.*

---

---

---

---

Beschreiben Sie Ransomware mit Bezug auf Verbreitungsmethode und Schadfunktionalität.

*Describe ransomware with respect to propagation and payload.*

---

---

---

---

---

Beschreiben Sie die drei üblichen Verfahren, um Malware zu erkennen und vergleichen Sie sie zusätzlich in den Dimensionen Genauigkeit, Geschwindigkeit und Effizienz.

*Describe the three common approaches for malware detection and in addition discuss them in terms of accuracy, speed, and efficiency.*

---

---

---

---

---

---

---

---

---

---

**4. Zugriffssteuerung / Access Control (4 + 2 + 4 = 10)**

a) Besondere DACLs

*Special DACLs*

Was ist der Unterschied zwischen einer NULL DACL und einer leeren DACL?

*What is the difference between a NULL DACL and an empty DACL?*

---

---

---

---

b) Tokens

Ein Token in der Zugriffssteuerung von Windows enthält die SIDs der Gruppen, in denen das im Token enthaltene Benutzerkonto Mitglied ist. Wie wirken sich Veränderungen in Gruppenmitgliedschaften auf ein existierendes Token aus?

*A token in Windows access control contains the SIDs of the groups of which the user is a member. How do changes in group membership affect an existing token?*

---

---

---

---

c) Inhalt von Strukturen der Zugriffssteuerung

*Content of structures in access control*

Gegeben sei folgende Zugriffssteuerungsmatrix:

*Consider the following access matrix:*

|          | Instagram | KakaoTalk | Spotify | YouTube |
|----------|-----------|-----------|---------|---------|
| Contacts | RW        | RW        | R       |         |
| Location | R         | R         |         |         |
| Music    |           | R         | RW      |         |
| Pictures | RW        | RW        |         |         |

Schreiben Sie alle nichtleeren Zugriffssteuerungslisten auf.

*Write down all nonempty access control lists.*

---



---



---



---

Schreiben Sie alle nichtleeren Fähigkeitslisten auf.

*Write down all nonempty capability lists.*

---



---



---



---

## 5. Positivlisten / Whitelisting (5 + 2 + 6 + 4 = 17)

a) Windows Defender Application Control (WDAC)

Kreuzen Sie alle richtigen und nur die richtigen Antworten an.

*Mark all correct answers and only correct answers.*

- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen eine Anwendung Daten schreiben darf.  
*A path-based application whitelist in WDAC specifies to which directories an application is allowed to write.*
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen Dateien ausgeführt werden dürfen.  
*A path-based application whitelist in WDAC specifies in which directories files are allowed to be executed.*
- ☐ Eine pfadbasierte Positivliste in WDAC nennt man Fähigkeitsliste.  
*A path-based application whitelist in WDAC is called a capability list.*
- ☐ Eine pfadbasierte Positivliste in WDAC kann mit einer zertifikatbasierten Positivliste kombiniert werden.  
*A path-based application whitelist in WDAC can be combined with a certificate-based application whitelist.*
- ☐ Eine pfadbasierte Positivliste in WDAC betrifft alle Benutzerinnen und Benutzer auf einem Gerät, einschließlich derjenigen in der Gruppe Administratoren.  
*A path-based application whitelist in WDAC applies to all users on a machine, including those in the Administrators group.*

b) Wozu dient der Audit Mode?

*What is the purpose of the audit mode?*

---

---

---

---

---

c) Inhalt einer typischen Positivliste

*Content of a typical whitelist*

Kreuzen Sie alle (und nur die) Pfade an, die in eine pfadbasierte Positivliste für einen üblichen Büro-Arbeitsplatz gehören.

*Mark all (and only those) paths that belong in a path-based application whitelist for a typical personal computer in an office.*

- ☐ C:\
- ☐ C:\Programme\  
C:\Program Files\
- ☐ C:\Programme (x86)\  
C:\Program Files (x86)\
- ☐ C:\Benutzer\  
C:\Users\
- ☐ C:\Benutzer\Administrator\  
C:\Users\Administrator\
- ☐ C:\Benutzer\Öffentlich\  
C:\Users\Public\
- ☐ C:\Windows\
- ☐ C:\Windows\system32\
- ☐ C:\Windows\temp\
- ☐ USB-Sticks  
USB memory drives
- ☐ Externe Festplatten  
External hard drives
- ☐ Netzlaufwerke  
Network shares

d) Welche Herausforderungen sehen Sie für Positivlisten in PC-Pools einer Hochschule? Welche zusätzlichen oder alternativen Schutzmechanismen empfehlen Sie bei einer geplanten Einführung von Positivlisten für PC-Pools?

*What challenges do you see for whitelists for computer labs at a university? What additional or alternative protection mechanisms do you recommend for a planned introduction of whitelists for computer labs?*

---

---

---

---

---

---

---

---



**6. CWE-120, CWE-367 (6 + 3 = 9)**

Erklären Sie Buffer-Overflow-Schwachstellen. Nehmen Sie anschließend die Behandlung von Strings in Java und C als Beispiel dafür, wie die Wahl der Programmiersprache beeinflusst, welche Arten von Schwachstellen in Software auftreten können.

*Explain buffer overflow vulnerabilities. Then use string handling in both Java and C as an example why the choice of programming language affects what types of vulnerabilities can occur in software.*

[illegible]

Die folgenden Programmzeilen geben den Inhalt einer Datei aus, wenn der Benutzer Besitzer der Datei ist. Zeigen Sie die enthaltene Race Condition auf und erläutern Sie, wie diese durch einen Angreifer dazu ausgenutzt werden könnte, dass das Programm eine andere Datei öffnet als diejenige, die der Benutzer öffnen möchte.

*The following code prints the contents of a file if a user has permission. Point out the race condition and how that might be exploited by an attacker to have the program open a different file than the one intended by the user.*

```
function readFile($filename){
    $user = getCurrentUser();
    $realFile = $filename;

    //resolve file if its a symbolic link
    if(is_link($filename)){
        $filename = readlink($filename);
    }

    if(fileowner($filename) == $user){
        echo file_get_contents($realFile);
        return;
    }
    else{
        echo 'Access denied';
        return false;
    }
}
```

**7. Techniken / Techniques (6 + 4 = 10)**

Wie funktioniert Fuzzing, wie kann es zu zuverlässigerer Software beitragen und was sind seine Grenzen?

*How does fuzzing work, how can it help to improve software reliability and what are its limits?*

---

---

---

---

---

---

---

---

Erklären Sie Taint Analysis mithilfe der folgenden Programmzeilen.

*Explain taint analysis using the following source code.*

```
$a = $_GET['id'];  
$b = "...". $a;  
$c = rmvNonAlphabetic($b);  
if(...)  
    echo($c);  
else  
    echo($b);
```

---

---

---

---

---

---

---

---

---

---

## 8. Microsoft SDL (10)

Wählen Sie fünf Praktiken aus Microsofts SDL und erklären Sie sie.

*Pick five practices of Microsoft's SDL and explain them*

[illegible]

## 9. Zertifizierung / Certification (6 + 2 = 8)

Die Foobar-Software der ACME Corp. hat eine EAL4-Evaluierung nach Common Criteria erfolgreich abgeschlossen.

*The Foobar software of ACME Corp. was successfully evaluated at EAL4 according to the Common Criteria product evaluation scheme.*

- a) Was sind Tätigkeiten einer Evaluatorin für die genannten EALs, die nicht bereits für niedrigere EALs verpflichtend sind?

*What are specific activities performed by an evaluator at the given EAL that are not mandatory for the lower EALs?*

EAL2 (zusätzlich zu / *added activities compared to* EAL1)

---

---

---

EAL3 (zusätzlich zu / *added activities compared to* EAL2)

---

---

---

EAL4 (zusätzlich zu / *added activities compared to* EAL3)

---

---

---

- b) Was sind die fünf Themen der Security Problem Definition in einem Security Target nach CC?  
*What are the five topics of the security problem definition in a CC security target?*

---

---

---

---

---

## 10. Passwörter / Passwords (2 + 2 + 2 + 2 = 8)

Passwörter sind eine der am weitesten verbreiteten Authentisierungstechniken.

*Passwords are among the most widely used authentication mechanisms.*

- a) Was ist die minimale Länge von Passwörtern an der HTWG Konstanz?

*What is the minimum length of passwords at HTWG Konstanz?*

---

- b) Passwörter werden nicht im Klartext, sondern es wird ihr Hash-Wert gespeichert. Warum?

*Passwords are not stored in cleartext, instead, their hash value is stored. Why?*

---

---

---

---

---

---

- c) Was versteht man unter Salting von Passwörtern?

*What is salting of passwords?*

---

---

---

---

- d) Muss ein Salt-Wert geheim gehalten werden?

*Does a salt value need to be secret?*

---